Análise de arquivo suspeito

Share

exec.jar

JAR

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Avaliando o papel das regras de segurança

Vou fazer uma análise estática, sem executar o arquivo em nenhum momento. Começo consultando a orientação para ler arquivos enviados.

Ler a skill de leitura de arquivos para saber como tratar arquivos compactados como …

Um `.jar` é um arquivo ZIP. Vou começar pela identificação básica (tipo, tamanho e hashes) e listar o conteúdo, sem extrair nada ainda.

Ran 5 commands, created a file

A classe principal só carrega a interface (título da janela: "JavaLocker", janela não redimensionável). Nada perigoso nela. A lógica real fica nas classes do controlador. Vou ver a principal.

Ran 9 commands, read a file

Veredito: o arquivo **não é benigno**. O `exec.jar` é um **falso ransomware (scareware)**, uma tela de resgate chamada "JavaLocker" feita para intimidar a vítima e pedir US$ 300 em Bitcoin. Pela análise, porém, ele **não tem capacidade real de criptografar, apagar ou roubar arquivos**. A intenção é maliciosa (engano e extorsão), mas o impacto técnico direto no computador é praticamente nulo.

A análise foi estática e o arquivo nunca foi executado.

Passo a passo

1. **Identificação:** é um JAR íntegro de 18.062 bytes, sem dados extras ou comentário no ZIP e sem assinatura digital. SHA-256: `b3b16c75…0250234` (completo no fim).
2. **Conteúdo:** só 3 classes Java 8, um arquivo FXML (interface) e uma imagem. Não há DLLs, executáveis, outros JARs nem bibliotecas embutidas. O manifesto aponta para `javafxapplicationtest.JavaFXApplicationTest`, e tudo foi compilado em 08/03/2020.
3. **Interface (FXML):** um texto vermelho diz "You has become a victim of JavaLocker Ransomware!!!", com botão "Encrypt", link "What is bitcoin?" e seletor de idioma. Não há scripts embutidos.
4. **Código (desmontado com `javap`):**

    - A janela se chama “JavaLocker” e é comum: pode ser fechada normalmente.
    - O programa escolhe a nota de resgate, em 6 idiomas, conforme o idioma do sistema.
    - O link “What is bitcoin?” só abre uma busca no Bing.
    - O botão “Encrypt” apenas mostra um alerta de erro, “Cannot connect to the service!!!”, e termina.
5. **Varredura de capacidades:** procurei criptografia, leitura e escrita de arquivos, execução de comandos, rede, reflexão e persistência em todo o JAR, sem nenhum resultado.
6. **Dados ocultos:** o `lock.jpg` é só um cadeado preto, com estrutura JPEG válida. Os metadados são Exif e XMP padrão, sem payload. Não há lacunas nem bytes sobrando no ZIP.
7. **Sinais de amadorismo:**
    - O “endereço Bitcoin” da nota é inválido (contém “O”, que não existe em Base58, e não começa com 1, 3 ou bc1), então ninguém conseguiria pagar nele.
    - Os domínios “torporject” têm erro de digitação (o correto é torproject.org). Pode ser descuido do autor ou typosquatting; não consegui verificar de quem são.
    - Os nomes de arquivo são típicos do template JavaFX do NetBeans.

Por que não “benigno” nem “ransomware real”

Todo o propósito do programa é simular um ataque e extorquir, sem uso legítimo além de demonstração, aula ou pegadinha. Usado contra alguém desavisado, funciona como extorsão por engano. Por outro lado, ele não executa nenhuma ação destrutiva.

Ressalvas

- Não consultei bases como o VirusTotal, porque estou sem acesso à rede. Vale pesquisar o hash lá.
- O nome `exec.jar` pode indicar que este arquivo é só a “tela” de um conjunto maior. Se você o encontrou numa máquina cujos arquivos foram realmente cifrados, o componente que cifra está em outro lugar (outro JAR, executável ou script), e este arquivo sozinho não explicaria o dano.

Recomendações

- Se você já abriu o arquivo, basta fechar a janela. Não há código de persistência.
- Só execute de novo em VM ou sandbox, não acesse os domínios `torporject[.]com` e `torporject[.]org` e não envie Bitcoin.
- Se o arquivo chegou como ameaça por e-mail ou mensagem, guarde a mensagem e denuncie.
- Se houver arquivos realmente cifrados, desconecte a máquina da rede, não apague nada e consulte o nomoreransom.org ou um profissional de resposta a incidentes.

Indicadores para referência

- SHA-256 do `exec.jar`: `b3b16c750842b994a6503e8feae909b730d0eff9bce5081049c498cb30250234`

- SHA-256 do `FXMLDocumentController.class`: `7f12da00909955b73a004d13c3999f66e72480c3c855b7574a0f450d39a904ac`
- Strings: `JavaLocker`, `BAW4VM2dhxYgXeQepOHKHSQVG6NgaEb94`, `torporject[.]com`, `torporject[.]org`

Qual é a categoria principal deste malware?

Explicando o que a amostra faz de fato e de que categoria ela é

A categoria principal é **scareware, ou falso ransomware**: um programa que imita um ataque de ransomware para assustar a vítima e induzi-la a pagar, sem executar o ataque de verdade.

O que o coloca aí, e não em categorias vizinhas:

- **Não é ransomware criptográfico**, porque não há código de criptografia nem acesso a arquivos. O botão "Encrypt" só mostra um alerta de erro.
- **Não chega a ser um "locker" de tela.** A janela é comum: não ocupa a tela cheia, não fica sempre no topo e pode ser fechada normalmente.
- **Tem as características do scareware:** nota de resgate em 6 idiomas, valor em Bitcoin, imagem de cadeado e um botão que simula a "liberação" dos arquivos.

Como o programa é só uma fachada, o enquadramento depende do uso. Em demonstração, aula ou trote, é um *joke/prank* ou prova de conceito. Entregue a uma vítima desavisada, é extorsão por engano. Os antivírus costumam rotulá-lo de formas diferentes, algo como trojan/ransom genérico (por causa das strings) ou *joke*, mas não pude conferir isso sem acesso à rede.

Se este JAR fizer parte de um pacote maior, com um componente separado que realmente cifra arquivos, a família seria **ransomware criptográfico** e este arquivo seria só o módulo da tela de resgate. Com o que há aqui, o que posso afirmar é scareware.